

COMPTE RENDU – TP 4.1 : MISE EN PLACE D'UN PARE-FEU pfSense ET SEGMENTATION DU LABORATOIRE

Introduction

Le présent travail s'inscrit dans une démarche de sécurisation des infrastructures réseau au sein d'un environnement virtualité. L'enjeu majeur de ce TP est de rompre avec une architecture "flat network" (réseau plat), où toutes les entités communiquent sans restriction, pour migrer vers une structure segmentée et contrôlée.

Pour ce faire, nous avons implémenté une solution de pare-feu **pfSense**, agissant comme une passerelle de sécurité entre deux zones distinctes :

1. Architecture et adressage réseau

Afin de garantir une isolation efficace des flux, l'infrastructure a été segmentée en deux zones distinctes, orchestrées par le pare-feu pfSense qui sert de pivot central.

2.1. Topologie de la Zone LAN (Réseau Interne)

La zone de confiance, ou **LAN**, utilise le plan d'adressage privé **192.168.1.0/24**. Dans ce périmètre, pfSense occupe l'adresse **192.168.1.1**, faisant office de passerelle par défaut pour toutes les machines clientes.

- Les stations de travail, incluant les systèmes **Ubuntu** et **Windows**, sont configurées sur ce segment avec des adresses statiques (notamment **192.168.1.20**), pointant systématiquement vers l'interface LAN de pfSense pour toute sortie réseau.

2.2. Configuration de la Zone WAN (Accès Externe)

L'interface **WAN** de pfSense est configurée pour simuler une sortie vers un réseau public. Elle récupère son adressage via un serveur **DHCP** externe (mode NAT dans l'environnement de

virtualisation), ce qui lui permet d'assurer la connectivité nécessaire au téléchargement des mises à jour et des signatures de sécurité pour l'IDS.

2.3. Accès à l'administration

L'administration du dispositif s'effectue exclusivement via l'interface Web sécurisée (**HTTPS**) à l'adresse **192.168.1.1**. Cet accès est protégé par des identifiants d'administration, permettant une gestion granulaire des règles de filtrage et du moteur Suricata depuis n'importe quel poste du LAN autorisé.

```
Starting syslog...done.
Starting CRON... done.
pfSense 2.4.5-RELEASE (Patch 1) amd64 Tue Jun 02 17:51:17 EDT 2020
Bootup complete

FreeBSD/amd64 (pfSense.localdomain) (ttyv0)

VirtualBox Virtual Machine - Netgate Device ID: 8c68492bf8a90a5d2c8b

*** Welcome to pfSense 2.4.5-RELEASE-p1 (amd64) on pfSense ***

WAN (wan)      -> em0      -> v4/DHCP4: 192.168.43.46/24
LAN (lan)      -> em1      -> v4: 192.168.1.1/24

0) Logout (SSH only)          9) pfTop
1) Assign Interfaces          10) Filter Logs
2) Set interface(s) IP address 11) Restart webConfigurator
3) Reset webConfigurator password 12) PHP shell + pfSense tools
4) Reset to factory defaults  13) Update from console
5) Reboot system              14) Enable Secure Shell (sshd)
6) Halt system                 15) Restore recent configuration
7) Ping host                   16) Restart PHP-FPM
8) Shell

Enter an option: █
```

2.4 Ubuntu

```
sudo ip addr add 192.168.1.10/24 dev eth0
```

```
sudo ip route add default via 192.168.1.1
```

```
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: enp0s3: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:50:5f:02 brd ff:ff:ff:ff:ff:ff
    altname enx080027505f02
    inet 192.168.1.10/24 brd 192.168.1.255 scope global noprefixroute enp0s3
        valid_lft forever preferred_lft forever
```

2.5 Windows

IP : 192.168.1.20

Masque : 255.255.255.0

Passerelle : 192.168.1.1

```
pfSense 2.4.5-RELEASE (Patch 1) amd64 Tue Jun 02 17:51:17 EDT 2020
Bootup complete

FreeBSD/amd64 (pfSense.localdomain) (ttyv0)

VirtualBox Virtual Machine - Netgate Device ID: 5bf4e498b0896abab7cb

*** Welcome to pfSense 2.4.5-RELEASE-p1 (amd64) on pfSense ***

WAN (wan)      -> em0      -> v4/DHCP4: 10.0.2.15/24
                v6/DHCP6: fd17:625c:f037:2:a00:27ff:fe99:ebdf/
64
LAN (lan)      -> em1      -> v4: 192.168.1.1/24

0) Logout (SSH only)          9) pfTop
1) Assign Interfaces          10) Filter Logs
2) Set interface(s) IP address 11) Restart webConfigurator
3) Reset webConfigurator password 12) PHP shell + pfSense tools
4) Reset to factory defaults    13) Update from console
5) Reboot system              14) Enable Secure Shell (sshd)
6) Halt system                15) Restore recent configuration
7) Ping host                  16) Restart PHP-FPM
8) Shell

Enter an option: █
```

3. Phase de tests initiaux et validation de la politique par défaut

Avant toute restriction granulaire, il est crucial d'établir un état des lieux de la connectivité réseau. Cette étape permet de confirmer que la passerelle pfSense est correctement positionnée et que le routage entre le segment LAN et le WAN est opérationnel.

3.1. Analyse de la politique "Allow All" (Sortie d'usine)

Par défaut, pfSense applique sur l'interface LAN une règle de type **Pass** (Autoriser). Cette règle est configurée pour accepter tout type de protocole, sans distinction de source ou de destination.

- **Objectif** : Vérifier que les machines du réseau interne peuvent atteindre des hôtes sur Internet avant que nous n'appliquions des règles de filtrage plus strictes.

3.2. Test de connectivité ICMP (Ping)

Pour valider cette communication, nous avons utilisé l'utilitaire de diagnostic intégré à pfSense (Option 7 du menu console).

- **Action** : Exécution d'une requête Ping vers le serveur DNS public de Google (**8.8.8.8**).
- **Résultat obtenu** : Comme illustré dans la capture de la console, les paquets ICMP ont été transmis avec succès, affichant un temps de réponse moyen (RTT) stable.
- **Conclusion** : Ce test confirme que la pile TCP/IP est fonctionnelle, que la translation d'adresses (NAT) sur le WAN s'effectue correctement et que pfSense peut communiquer avec l'extérieur.

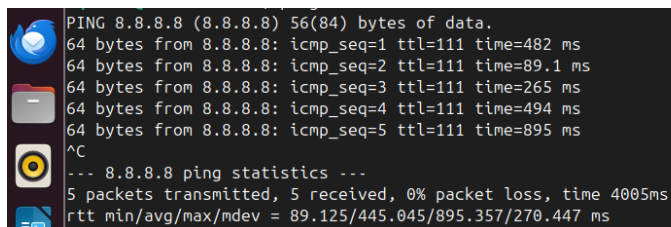
```
Enter an option: 7

Enter a host name or IP address: 8.8.8.8

PING 8.8.8.8 (8.8.8.8): 56 data bytes
64 bytes from 8.8.8.8: icmp_seq=0 ttl=255 time=396.389 ms
64 bytes from 8.8.8.8: icmp_seq=1 ttl=255 time=380.566 ms
64 bytes from 8.8.8.8: icmp_seq=2 ttl=255 time=349.660 ms

--- 8.8.8.8 ping statistics ---
3 packets transmitted, 3 packets received, 0.0% packet loss
round-trip min/avg/max/stddev = 349.660/375.538/396.389/19.405 ms

Press ENTER to continue.
```



```
PING 8.8.8.8 (8.8.8.8) 56(84) bytes of data:
64 bytes from 8.8.8.8: icmp_seq=1 ttl=111 time=482 ms
64 bytes from 8.8.8.8: icmp_seq=2 ttl=111 time=89.1 ms
64 bytes from 8.8.8.8: icmp_seq=3 ttl=111 time=265 ms
64 bytes from 8.8.8.8: icmp_seq=4 ttl=111 time=494 ms
64 bytes from 8.8.8.8: icmp_seq=5 ttl=111 time=895 ms
^C
--- 8.8.8.8 ping statistics ---
5 packets transmitted, 5 received, 0% packet loss, time 4005ms
rtt min/avg/max/mdev = 89.125/445.045/895.357/270.447 ms
```

Conclusion : Avec la règle par défaut, tout le trafic est autorisé (sortant du LAN). Cela ne protège pas contre un attaquant qui compromettrait une machine interne.

4. Durcissement de la politique de sécurité (Filtrage granulaire)

Après avoir validé la connectivité de base, l'objectif est de passer d'un réseau ouvert à une politique de **moindre privilège**. Cela consiste à interdire par défaut tout trafic non essentiel afin de réduire la surface d'attaque.

4.1. Objectif du filtrage

La stratégie adoptée vise à restreindre les flux sortants du LAN uniquement vers le service de navigation web standard.

- **Autorisation** : Protocole HTTP uniquement (Port 80).
- **Interdiction** : Blocage systématique de tous les autres flux, notamment le protocole ICMP (Ping), le HTTPS (443), ainsi que toute tentative de scan de ports ou d'exfiltration de données via d'autres vecteurs.

4.2. Spécifications techniques de la règle

Pour implémenter ce contrôle, une règle spécifique a été créée et positionnée en priorité sur l'interface LAN de pfSense. Voici les paramètres configurés :

- **Action** : **Pass** (Autoriser le flux sélectionné).
- **Interface** : **LAN** (S'applique au trafic provenant du réseau interne).
- **Protocole** : **TCP** (Protocole de transport utilisé par le HTTP).
- **Source** : **Any** (Toute machine située sur le segment LAN).
- **Destination** : **Any** (Toute adresse IP située sur le réseau externe WAN).
- **Port de destination** : **HTTP (80)**.

4.3. Impact sur la sécurité réseau

En appliquant cette règle, pfSense rejette désormais implicitement toute requête qui ne correspond pas strictement à du trafic web sur le port 80. Ce mécanisme est fondamental pour

empêcher un attaquant ou un logiciel malveillant d'utiliser des protocoles arbitraires pour communiquer avec l'extérieur, tout en maintenant un accès web fonctionnel pour les utilisateurs.

The screenshot shows the 'firewall_rules_edit.php' page in a web browser. The configuration is for the LAN interface, IPv4 protocol, and TCP. The source is set to 'any' and the destination port range is 'HTTP (80)'. The 'Log' checkbox is unchecked.

Interface: LAN
Choose the interface from which packets must come to match this rule.

Address Family: IPv4
Select the Internet Protocol version this rule applies to.

Protocol: TCP
Choose which IP protocol this rule should match.

Source

Source: ☐ Invert match any Source Address /

Destination

Destination: ☐ Invert match any Destination Address /

Destination Port Range: HTTP (80) From Custom To Custom
Specify the destination port or port range for this rule. The 'To' field may be left empty if only filtering a single port.

Extra Options

Log: ☐ Log packets that are handled by this rule
Hint: the firewall has limited local log space. Don't turn on logging for everything. If doing a lot of logging, consider using a remote syslog server (see the [Status: System Logs: Settings](#) page).

The screenshot shows the 'Firewall / Rules / LAN' page in the pfSense web interface. A warning message indicates that the 'admin' account password is set to the default value. A yellow message box states that the firewall rule configuration has been changed and must be applied. The table below lists the rules for the LAN interface.

WARNING: The 'admin' account password is set to the default value. [Change the password in the User Manager.](#)

Firewall / Rules / LAN

The firewall rule configuration has been changed. The changes must be applied for them to take effect. [Apply Changes](#)

Rules (Drag to Change Order)

	States	Protocol	Source	Port	Destination	Port	Gateway	Queue	Schedule	Description	Actions
☐	1 / 843 KIB	*	*	*	LAN Address	443 80	*	*		Anti-Logout Rule	Settings
☐	0 / 0 B	IPv4 TCP	LAN net	*	*	80 (HTTP)	*	none			Add Edit Delete Save Separator
☐	17 / 958 KIB	IPv4 *	LAN net	*	*	*	*	none		Default allow LAN to any rule	Add Edit Delete Save Separator
☐	0 / 0 B	IPv6 *	LAN net	*	*	*	*	none		Default allow LAN IPv6 to any rule	Add Edit Delete Save Separator

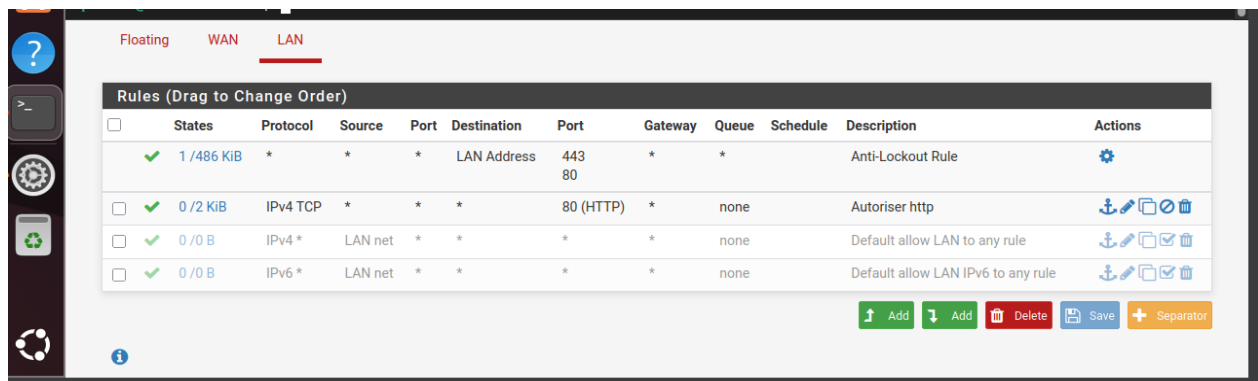
[Add](#) [Add](#) [Delete](#) [Save](#) [Separator](#)

Règle par défaut désactivée

Les règles par défaut ont été désactivées pour ne laisser passer que ce que nous autorisons explicitement.

```
(BEL-ANGE@kali)-[~]
$ curl http://google.com
curl: (6) Could not resolve host: google.com

(BEL-ANGE@kali)-[~]
$ curl http://142.250.185.46
<HTML><HEAD><meta http-equiv="content-type" content="text/html; charset=utf-8">
<TITLE>301 Moved</TITLE></HEAD><BODY>
<H1>301 Moved</H1>
The document has moved
<A HREF="http://www.google.com/">here</A>.
</BODY></HTML>
```



- Problème constaté avec curl http://8.8.8.8

Lors des premiers tests, la commande :

```
curl http://8.8.8.8
```

a échoué avec le message :

```
curl: (28) Failed to connect to 8.8.8.8 port 80 after 134556 ms
```

- Explication technique

8.8.8.8 est un serveur DNS public de Google, pas un serveur web.

Il écoute uniquement sur le port 53 UDP/TCP, pas sur le port 80 HTTP.

L'échec n'est pas lié au pare-feu, mais à la cible elle-même.

- Solution adoptée

Nous avons utilisé une adresse IP qui répond réellement sur le port 80 :

```
curl http://142.250.185.46
```

```
(BEL-ANGE@kali)-[~]
$ curl http://8.8.8.8
curl: (56) Recv failure: Connexion ré-initialisée par le correspondant

(BEL-ANGE@kali)-[~]
$ curl http://google.com
<HTML><HEAD><meta http-equiv="content-type" content="text/html; charset=utf-8">
<TITLE>301 Moved</TITLE></HEAD><BODY>
<H1>301 Moved</H1>
The document has moved
<A HREF="http://www.google.com/">here</A>.
</BODY></HTML>

(BEL-ANGE@kali)-[~]
$ curl http://142.250.185.46
<HTML><HEAD><meta http-equiv="content-type" content="text/html; charset=utf-8">
<TITLE>301 Moved</TITLE></HEAD><BODY>
<H1>301 Moved</H1>
The document has moved
<A HREF="http://www.google.com/">here</A>.
</BODY></HTML>

(BEL-ANGE@kali)-[~]
$ curl http://8.8.8.8
```

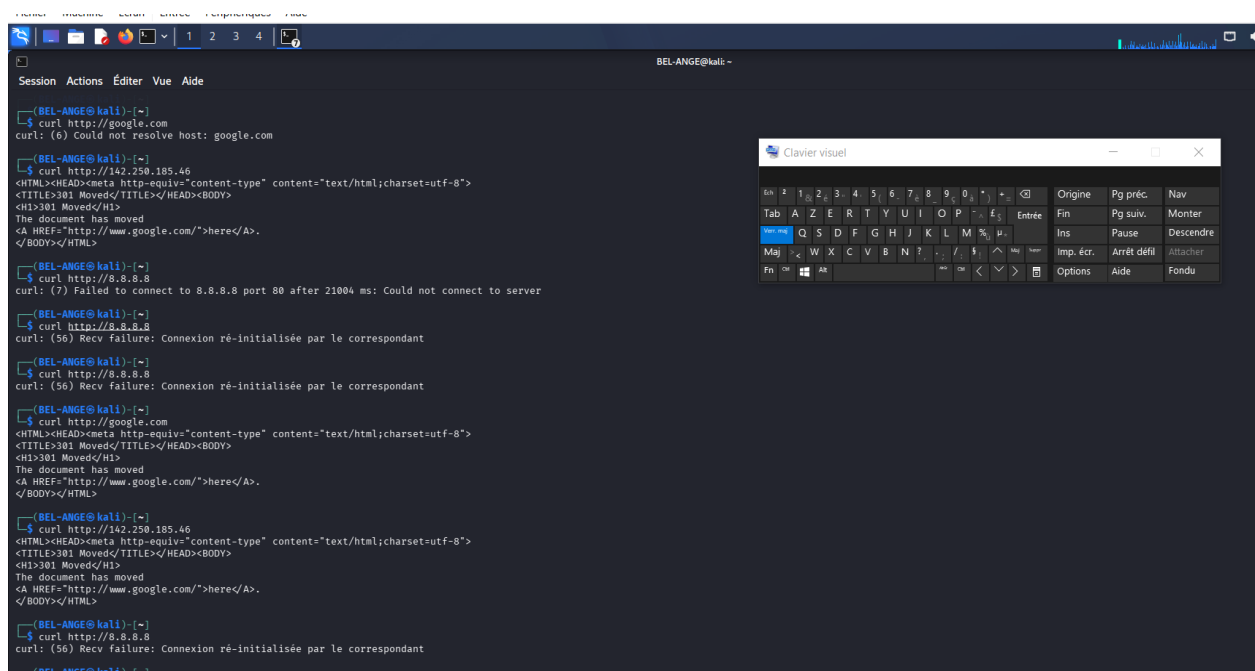
5. Test de scan nmap (depuis Kali)

Conformément à votre déroulement réel :

« nmap a été lancé depuis Kali, car Ubuntu n'avait pas nmap installé et nécessitait des paquets supplémentaires. »

Commande exécutée depuis Kali (connecter au LAN uniquement pour cette commande) vers 8.8.8.8 :

nmap -sS 8.8.8.8



```
Session Actions Éditer Vue Aide

(BEL-ANGE@kali)-[~]
$ curl http://google.com
curl: (6) Could not resolve host: google.com

(BEL-ANGE@kali)-[~]
$ curl http://142.250.185.46
<HTML><HEAD><meta http-equiv="content-type" content="text/html; charset=utf-8">
<TITLE>301 Moved</TITLE></HEAD><BODY>
<H1>301 Moved</H1>
The document has moved
<A HREF="http://www.google.com/">here</A>.
</BODY></HTML>

(BEL-ANGE@kali)-[~]
$ curl http://8.8.8.8
curl: (7) Failed to connect to 8.8.8.8 port 80 after 21004 ms: Could not connect to server

(BEL-ANGE@kali)-[~]
$ curl http://8.8.8.8
curl: (56) Recv failure: Connexion ré-initialisée par le correspondant

(BEL-ANGE@kali)-[~]
$ curl http://8.8.8.8
curl: (56) Recv failure: Connexion ré-initialisée par le correspondant

(BEL-ANGE@kali)-[~]
$ curl http://google.com
<HTML><HEAD><meta http-equiv="content-type" content="text/html; charset=utf-8">
<TITLE>301 Moved</TITLE></HEAD><BODY>
<H1>301 Moved</H1>
The document has moved
<A HREF="http://www.google.com/">here</A>.
</BODY></HTML>

(BEL-ANGE@kali)-[~]
$ curl http://142.250.185.46
<HTML><HEAD><meta http-equiv="content-type" content="text/html; charset=utf-8">
<TITLE>301 Moved</TITLE></HEAD><BODY>
<H1>301 Moved</H1>
The document has moved
<A HREF="http://www.google.com/">here</A>.
</BODY></HTML>

(BEL-ANGE@kali)-[~]
$ curl http://8.8.8.8
curl: (56) Recv failure: Connexion ré-initialisée par le correspondant

(BEL-ANGE@kali)-[~]
```



```
└─$ nmap -SS 142.250.185.46
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-28 08:57 +0200
Note: Host seems down. If it is really up, but blocking our ping probes, try -Pn
Nmap done: 1 IP address (0 hosts up) scanned in 3.10 seconds
```

Conclusion

La manipulation de ce tp m'a permis de

- Segmenter un laboratoire avec pfSense
- Comprendre la différence entre IP fonctionnelle pour HTTP (ex: 142.250.185.46) et IP non web (8.8.8.8)
- Constater que le filtrage peut bloquer DNS, rendant nécessaire l'usage d'IP directes
- Réaliser un test d'attaque depuis Kali car Ubuntu ne dispose pas de tous les outils
- Valider qu'un pare-feu bien configuré limite très fortement les capacités d'un attaquant